

Security Check Report

Domain: demo-shop.test Date: 04 October 2026 Checked by: Victor

Problems found

Critical	High	Medium	Low
1	2	4	7

Fix these first

CRITICAL Settings file with secrets is public

Why it matters: This file usually holds passwords and keys. Anyone can read them.

What to do: Remove it from the public folder or block it in your web server settings. Change every password and key it held. Treat them as stolen.

HIGH SPF allows any sender

Why it matters: It tells receivers that any server may send as you.

What to do: Change the ending to -all, or ~all while you test.

HIGH No DMARC record

Why it matters: Nothing tells receivers to block mail that fakes your domain.

What to do: Add a TXT record at _dmarc with: v=DMARC1; p=none; rua=mailto:you@yourdomain. Review the reports, then move to p=quarantine and later p=reject.

MEDIUM HSTS is not set

Why it matters: Browsers are not told to always use HTTPS for this site.

What to do: Add the header: Strict-Transport-Security: max-age=31536000

MEDIUM HTTP does not redirect to HTTPS

Why it matters: Visitors who type the plain address stay on an unprotected page.

What to do: Set a permanent redirect from http:// to https://.

9 more problems are listed in the technical details.

Already good

- Certificate is valid

Technical details

CRITICAL Settings file with secrets is public (paths)

https://demo-shop.test/.env is readable by anyone.

Evidence: HTTPS GET /.env -> 200; readable file with KEY=value lines (contents not stored) [2026-10-04T13:47:43+00:00]

Limit: Only a few common file addresses were requested, one time each. A clean result does not mean nothing is exposed. Contents are read briefly to confirm and are not stored.

HIGH SPF allows any sender (email)

The record ends with +all.

Evidence: v=spf1 +all [2026-10-04T13:47:43+00:00]

HIGH No DMARC record (email)

No DMARC record was found.

Evidence: TXT _dmarc.demo-shop.test: no v=DMARC1 record [2026-10-04T13:47:43+00:00]

MEDIUM HSTS is not set (tls)

No Strict-Transport-Security header.

Evidence: HTTPS GET / -> 200, no HSTS [2026-10-04T13:47:43+00:00]

MEDIUM HTTP does not redirect to HTTPS (tls)

The plain HTTP site answers without sending visitors to HTTPS.

Evidence: HTTP GET / -> 200 [2026-10-04T13:47:43+00:00]

MEDIUM No Content-Security-Policy (headers)

The Content-Security-Policy header is missing.

Evidence: HTTPS GET https://demo-shop.test/ -> 200 [2026-10-04T13:47:43+00:00]

Limit: Only the home page was requested. Other pages may send different headers.

MEDIUM Cookies without the Secure flag (headers)

Cookies missing it: session

Evidence: HTTPS GET https://demo-shop.test/ -> 200 | session=abc123; Path=/ [2026-10-04T13:47:43+00:00]

Limit: Only the home page was requested. Other pages may send different headers.

LOW DKIM not found among common selectors (email)

None of the common selectors returned a key.

Evidence: Tried: default, google, selector1, selector2, k1, mail, dkim, s1, s2 [2026-10-04T13:47:43+00:00]

Limit: DKIM selectors are private names. We only try common ones, so 'not found' does not prove DKIM is missing.

LOW No clickjacking protection (headers)

Neither X-Frame-Options nor frame-ancestors is set.

Evidence: HTTPS GET https://demo-shop.test/ -> 200 [2026-10-04T13:47:43+00:00]

Limit: Only the home page was requested. Other pages may send different headers.

LOW X-Content-Type-Options is not set (headers)

The header is missing or not 'nosniff'.

Evidence: HTTPS GET https://demo-shop.test/ -> 200 [2026-10-04T13:47:43+00:00]

Limit: Only the home page was requested. Other pages may send different headers.

LOW No Referrer-Policy (headers)

The Referrer-Policy header is missing.

Evidence: HTTPS GET https://demo-shop.test/ -> 200 [2026-10-04T13:47:43+00:00]

Limit: Only the home page was requested. Other pages may send different headers.

LOW Web server version is shown (headers)

The Server header shows: nginx/1.18.0

Evidence: HTTPS GET https://demo-shop.test/ -> 200 | Server: nginx/1.18.0 [2026-10-04T13:47:43+00:00]

Limit: Only the home page was requested. Other pages may send different headers.

LOW Cookies without the HttpOnly flag (headers)

Cookies missing it: session

Evidence: HTTPS GET https://demo-shop.test/ -> 200 | session=abc123; Path=/ [2026-10-04T13:47:43+00:00]

Limit: Only the home page was requested. Other pages may send different headers.

LOW Cookies without a SameSite setting (headers)

Cookies missing it: session

Evidence: HTTPS GET https://demo-shop.test/ -> 200 | session=abc123; Path=/ [2026-10-04T13:47:43+00:00]

Limit: Only the home page was requested. Other pages may send different headers.

What this check cannot see

This is an outside-in check of public information. It is not a full penetration test. It does not log in, test passwords, or look inside your systems. It can miss problems, and a clean report does not guarantee you are safe. Each finding lists its own limit.